

Rajo @rajo_PL · 13 sty

CYBERBEZPIECZEŃSTWO i AGENTYKA AI
Metodologia wykrywania systemowych oszustw E-Commerce.

Faza 1:
Analiza Powierzchniowa (frontend i dane prawne).

Pierwszym krokiem jest weryfikacja staranności informacyjnej sprzedawcy oraz spójności jego tożsamości biznesowej.
• Weryfikacja niezgodności branżowej:
Należy sprawdzić numer rejestrowy firmy (np. odpowiednik KRS/Regon) w oficjalnych bazach danych i porównać deklarowany profil działalności z faktycznym.
Oszuści często kradną tożsamość firm o niskim profilu ryzyka (np. pomoc społeczna), aby uwiarygodnić handel detaliczny.
• Wykrywanie błędów mapowania zmiennych:
Należy szukać unikalnych ciągów znaków w polach takich jak numer rejestrowy.
Wyciek wewnętrznych identyfikatorów technicznych (np. Merchant ID) do pól publicznych jest dowodem na masową, zautomatyzowaną produkcję stron-klonów.
• Analiza lingwistyczna i atrybucja kulturowa:
Należy szukać specyficznych dla danej jurysdykcji terminów (np. akronimów rejestrów gospodarczych) użytych na rynkach zagranicznych, co zdradza pochodzenie administratora szablonu.

Faza 2:
Analiza Głębokiej Infrastruktury (Kod Źródłowy i API).

W tej fazie wydobywa się 'cyfrowe odciski palców', których oszuści nie mogą ukryć bez zmiany całego modelu operacyjnego.
• Ekstrakcja unikalnego Shop ID:
Każdy sklep na platformach typu SaaS posiada stały identyfikator techniczny.
Znalezienie tego samego numeru na różnych domenach jest dowodem na współdzielenie tego samego konta administracyjnego i rozliczeniowego.

Znalezienie tego samego numeru na różnych domenach jest dowodem na współdzielenie tego samego konta administracyjnego i rozliczeniowego.
• Identyfikacja centralnego węzła uwierzytelniania (SSO Hub):
Należy przeanalizować adresy URL logowania (OAuth). Przekierowywanie użytkowników z różnych domen do jednej subdomeny technicznej dowodzi istnienia scentralizowanego 'mózgu' sieci i bazy danych ofiar.
• Analiza znaczników czasu (Timestamp Analysis): Analiza plików danych (np. .json) pozwala sprawdzić czas utworzenia rekordów produktów. Masowe dodawanie tysięcy pozycji w tej samej sekundzie (tzw. Superhuman Speed) jest matematycznym dowodem na użycie automatów (deployerów).

Faza 3:
Analiza sieciowa i behawioralna (DNS i Tracking).

Mapowanie połączeń między węzłami pozwala na prewencyjne blokowanie nowych zagrożeń.
• Krzyżowanie kluczy śledzących (Tracking Pixels): Porównanie unikalnych ID dla narzędzi analitycznych, nagrywania sesji oraz marketingu (np. Project ID, Pixel ID) pozwala powiązać z pozoru niezależne witryny z tym samym kontem administratora.
• Śledzenie łańcucha przekierowań (Redirect Chains): Analiza przekierowań (np. 301/302) z domen oznaczonych jako niebezpieczne na domeny nowe pozwala wykryć migrację grupy przestępczej i zachowanie ciągłości operacyjnej.
• Weryfikacja historyczna (Domain Aging): Sprawdzenie historii domeny (np. przejęcie starej domeny z inną branżą) pozwala wykryć techniki budowania fałszywego zaufania w algorytmach wyszukiwarek.

Rekomendacja:
Wykorzystanie Agentów AI w sektorze bankowym.

Aby skutecznie przeciwdziałać takim naruszeniom, banki powinny wdrożyć wyspecjalizowane Agenty AI, zdolne do wykonywania powyższej metodologii w czasie rzeczywistym:
1. AI OSINT Crawler:
Agent skanujący witryny merchantów w momencie procesowania płatności, wykrywający niezgodności branżowe (np. sklep z butami używający danych firmy np. opiekuńczej) i flagujący je do manualnej

ID, Pixel ID) pozwala powiązać z pozoru niezależne witryny z tym samym kontem administratora.
• Śledzenie łańcucha przekierowań (Redirect Chains): Analiza przekierowań (np. 301/302) z domen oznaczonych jako niebezpieczne na domeny nowe pozwala wykryć migrację grupy przestępczej i zachowanie ciągłości operacyjnej.
• Weryfikacja historyczna (Domain Aging): Sprawdzenie historii domeny (np. przejęcie starej domeny z inną branżą) pozwala wykryć techniki budowania fałszywego zaufania w algorytmach wyszukiwarek.

Rekomendacja:
Wykorzystanie Agentów AI w sektorze bankowym.

Aby skutecznie przeciwdziałać takim naruszeniom, banki powinny wdrożyć wyspecjalizowane Agenty AI, zdolne do wykonywania powyższej metodologii w czasie rzeczywistym:
1. AI OSINT Crawler:
Agent skanujący witryny merchantów w momencie procesowania płatności, wykrywający niezgodności branżowe (np. sklep z butami używający danych firmy np. opiekuńczej) i flagujący je do manualnej weryfikacji.
2. Linguistic & Technical Auditor:
Agent analizujący nagłówki komunikacji (e-maile) oraz strukturę kodu stron pod kątem anomalii językowych (np. holenderskie nagłówki w polskiej komunikacji) i technicznych (wycieki parametrów systemowych).
3. Network Linkage Engine:
System wykorzystujący uczenie maszynowe do mapowania powiązań między zablokowanymi kontami a nowymi merchantami na podstawie wspólnych identyfikatorów analitycznych (np. Project ID) i wzorców DNS.
4. Anomaly Detection in Payouts:
Agent monitorujący przepływy finansowe, który flaguje konta rozliczeniowe (Shop ID) zbierające wpłaty z wielu geograficznie rozproszonych domen o identycznym szablonie technicznym.

Analogia:
Metodologia ta działa jak badanie balistyczne. Nawet jeśli przestępca zmieni domenę, AI potrafi rozpoznać unikalne bruzdy na pocisku (ID techniczne, błędy w kodzie), które prowadzą do tego samego palca na spuście (administratora).